

Tập 6: Bảo mật với NetworkPolicy

Lý thuyết: Default-deny, NetworkPolicy vs AdminNetworkPolicy

Network Thực Chiến · Series: Kubernetes Networking · Tập 06

Thực trạng mặc định: Cluster K8s là "Wild West"

Mặc định, **mọi Pod đều có thể nói chuyện với mọi Pod** trong cluster — kể cả ở các namespace khác nhau!

```
frontend Pod (ns: app) —————> database Pod (ns: data)
payment Pod  (ns: app) —————> database Pod (ns: data)
logging Pod  (ns: infra)—————> database Pod (ns: data)
```

↑
KHÔNG CÓ GÌ CHẶN CẢ!

Trong môi trường Production với nhiều team, điều này là **rủi ro bảo mật nghiêm trọng** (lateral movement sau khi attacker chiếm được 1 Pod).

NetworkPolicy: Tường lửa cấp Pod

NetworkPolicy là Firewall rule được viết bằng YAML, hoạt động ở **Layer 3/4** (IP + Port):

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: allow-only-frontend
  namespace: data
spec:
  podSelector:
    matchLabels:
      app: database          # ← Áp dụng cho Pod nào?
  policyTypes:
    - Ingress
  ingress:
    - from:
      - namespaceSelector:
          matchLabels:
            name: app        # ← Chỉ cho phép từ namespace "app"
        podSelector:
          matchLabels:
            role: frontend  # ← Và chỉ Pod có label role=frontend
```

Nguyên tắc Default-deny

Khi bạn tạo **bất kỳ NetworkPolicy** nào chọn một Pod, Pod đó lập tức chuyển sang chế độ **Default-deny**:

- Mọi traffic **không được cho phép** từ **trình minh** sẽ bị **DROP**.
- Ngoại lệ: Traffic đến chính nó (localhost) vẫn luôn được phép.

```
# Áp dụng default-deny cho toàn bộ namespace
kubectl apply -f - <<EOF
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: default-deny-all
  namespace: production
spec:
  podSelector: {}          # ← {} nghĩa là chọn TẤT CẢ Pod
  policyTypes:
    - Ingress
    - Egress
EOF
```

! Lỗi kinh điển số 1: Chặn DNS

Sau khi áp dụng default-deny, ứng dụng trong Pod bị lỗi kết nối hoàn toàn — dù bạn đã mở đúng port!

Nguyên nhân: Egress deny đã chặn **cả DNS query** ra port 53 của CoreDNS!

```
# Kiểm tra DNS trong Pod
kubectl exec -it my-pod -- nslookup my-service
# Server: 10.96.0.10
# ;; connection timed out ← Lỗi DNS!
```

Fix: Luôn nhớ thêm rule cho phép DNS trong mọi NetworkPolicy:

```
egress:
  - ports:
    - port: 53
      protocol: UDP
    - port: 53
      protocol: TCP
```

AdminNetworkPolicy: Chính sách cấp Cluster

NetworkPolicy chỉ hoạt động trong phạm vi **1 namespace** và do Dev team quản lý.

AdminNetworkPolicy (ANP) là chuẩn mới (KEP-2091), được thiết kế cho Ops/Security team:

Tiêu chí	NetworkPolicy	AdminNetworkPolicy
Ai quản lý	Dev team (namespace)	Ops/Security team (cluster)
Phạm vi	Namespace	Toàn cluster
Hành động	Allow hoặc Deny (implicit)	Allow, Deny, Pass
Priority	Không có	Có (0-100)

ANP: Hành động Pass — Trao quyền cho Dev

Hành động **Pass** trong ANP cho phép Cluster Admin **ủy quyền** quyết định cho NetworkPolicy cấp namespace:

```
ANP Rule 1 (Priority 10): DENY traffic từ Internet → internal services
ANP Rule 2 (Priority 20): PASS traffic trong cùng namespace → Dev tự quyết
ANP Rule 3 (Priority 30): ALLOW traffic đến monitoring namespace
```



```
Nếu traffic match Rule 2 (PASS) → xem xét NetworkPolicy của namespace
→ Nếu NetworkPolicy ALLOW → traffic được phép
→ Nếu NetworkPolicy DENY   → traffic bị chặn
→ Nếu không có NP nào     → traffic được phép (behavior mặc định)
```

CNI và NetworkPolicy: Ai thực thi?

Quan trọng: K8s chỉ **lưu trữ** NetworkPolicy object vào etcd. Việc **thực thi** (enforcement) là nhiệm vụ của CNI plugin!

CNI	Cơ chế thực thi NetworkPolicy
Flannel	✗ Không hỗ trợ! (Cần kết hợp với Calico)
Calico	✓ Dùng iptables rules
Cilium	✓ Dùng eBPF maps (hiệu năng cao hơn)
Weave Net	✓ Dùng iptables

Nếu cluster dùng Flannel thuần mà bạn apply NetworkPolicy — sẽ không có tác dụng gì!

Tổng kết Tập 6

Khái niệm	Tóm tắt
Default Allow	Mặc định K8s cho phép mọi Pod-to-Pod traffic
NetworkPolicy	Firewall YAML cấp namespace, L3/L4, do Dev quản lý
Default-deny	Có bất kỳ Policy nào → Pod chuyển sang chế độ deny-by-default
Lỗi DNS	Lỗi số 1 sau khi apply NetworkPolicy: quên mở port 53
AdminNetworkPolicy	Policy cấp cluster, có Priority, hỗ trợ Allow/Deny/Pass

👉 Chuyển sang Lab 1.6

Mở file `lab-guide.md` trong thư mục `1.6/` để thực hành:

- Apply default-deny và quan sát DNS break
- Viết NetworkPolicy chuẩn mực (kèm DNS rule)
- Thử nghiệm trên Flannel (không có effect) vs Calico/Cilium